Rà soát code SF-01–SF-03 — 27/10/2026

Phạm vi và trạng thái

Rà lại logic và các đường đi của SF-01, SF-02, SF-03, bao gồm phần code đã viết trước đó. Sửa tại local theo yêu cầu người dùng; không commit, push, deploy hay gọi workflow từ xa. HEAD vẫn `61536542269d25af2a80c39b171d35aceaa29a94` . Không sửa smart contract hoặc chạy recovery trên dữ liệu thật. SF-04 (repository Organizer fallback sang memory) chưa được thay đổi trong lượt này.

Các lỗi được sửa thêm

Phần	Sai ở đâu	Sửa trong code	Bằng chứng
SF-01: phiên đọc	Chỉ so địa chỉ ví không phân biệt A→B→A; kết quả ký cũ có thể khôi phục phiên đã hủy	Credential có generation; chỉ kết quả thuộc đúng generation hiện tại được lưu	Test chờ signature, đổi A→B→A, trả signature cũ: không có credential hoặc API read
SF-01: cache	Hết hạn/reset mirror chưa xóa dữ liệu trong React Query cache	Hủy query và xóa private query cache khi mất credential	Test kiểm tra dữ liệu cache sau expiry, không chỉ kiểm tra UI
SF-02: deployment	Student proof buộc có Factory dù kiến trúc StudentRegistry độc lập	Ràng buộc proof với deployment theo purpose: StudentRegistry hoặc Factory	Test verifier thật vẫn nhận Student proof khi Factory trống
SF-02: trạng thái OTP	Chuyển email chỉ ẩn challenge/token, có thể khôi phục lại khi quay về; rate-limit callback có thể ghép	Xóa toàn bộ OTP session khi đổi identity; retry state chỉ giữ challenge cùng identity	Test A→B→A; email mới bị rate limit không có challenge cũ

Phần	Sai ở đâu	Sửa trong code	Bằng chứng
	requestId cũ vào identity mới		
SF-02: confirm UI	Có thể gọi verify thiếu requestId hoặc thiếu sáu số rồi vẫn mở ví	Kiểm tra challenge/code trước khi ký hoặc gọi API	Test không có wallet/API call khi thiếu challenge/code
SF-03: vòng đời upload	Async upload nằm trong form, không hủy kết quả ký/request khi đổi ví/vòng; không khóa thao tác lặp ở handler	Hook quản lý scope, generation, AbortController, submitting lock; reset hủy cả tác vụ chờ ký	Test đổi scope rồi quay lại, response muộn, double-click, reset khi đang ký
SF-03: file	MIME và đầu file đúng chưa chứng minh ảnh giải mã được; chưa chặn kích thước giải mã lớn	Sharp giải mã toàn bộ, giới hạn pixel/chiều/frame và bắt lỗi decode trước quota/provider	Test fake PNG, ảnh truncated vẫn đọc metadata, ảnh quá chiều; PNG/JPEG/WebP thật vẫn đi qua
CI local	Job-level env không phải chỗ hợp lệ để dùng context job.services	Đặt service container ID vào env của từng step	YAML/dependency/context placement kiểm tra local; chưa chạy GitHub Actions

Upload vẫn bắt chữ ký đúng hash/size/MIME/nonce, xác minh Student on-chain, dùng quota nguyên tử trong PostgreSQL, và chỉ gọi provider sau khi toàn bộ điều kiện hợp lệ. SQL migration 0008 không đổi trong lượt rà bổ sung; không cần migration mới cho thay đổi code này. Sharp được khai báo dependency trực tiếp và đồng bộ frozen lockfile, không dựa vào dependency gián tiếp của Next.js.

Kiểm tra hoàn tất

- 911 test ứng dụng qua; 13 integration test bỏ qua theo cấu hình. Test security dùng chữ ký EOA thật; chain/DB/provider được giả lập theo ranh giới test.
- 181 test Solidity qua; không sửa Solidity trong lượt này.
- TypeScript typecheck và Next.js webpack production build qua.

- ESLint: 0 lỗi, 5 warning unused hiện có; không thêm warning mới.
- Frozen lockfile qua kiểm tra pnpm 11.20.0 và chính sách dependency.
- SQL migrations/fixtures và concurrency quota đã qua trên PostgreSQL fixture trước đó; SQL không đổi. 12 request cùng ví: 5 nhận, 7 từ chối.
- Workflow YAML/context và syntax script Python kiểm tra local. Chưa chạy GitHub Actions/Docker service trên runner từ xa.
- Không có provider call thật trong kiểm thử upload. Mọi nhánh từ chối trong API tests assert provider fetch không được gọi.
- Kiểm tra các secret đã biết từ cấu hình local trong changed text files: không phát hiện; không in giá trị. Báo cáo/PDF kiểm tra riêng và dữ liệu fixture không tự đưa lên Git.

Giới hạn cần phân biệt

Đây là kết quả kiểm tra code local và fixture; không phải kết luận đã xác minh end-to-end bản mới trên production. SF-01/SF-02 từng triển khai là các phiên bản trước lượt rà này. SF-03 chưa deploy. Migration 0008 production do người dùng xác nhận đã chạy; Cloudinary API secret đã thêm trước đó, chỉ xác minh metadata. Chưa xác minh upload dương tính bằng ví Student fixture trên production hoặc vô hiệu unsigned preset qua Cloudinary Console.

Proof email/upload hiện phục vụ Core EOA, chưa hỗ trợ ERC-1271. Quota áp dụng cho API SqrtFund, không chặn credential/preset Cloudinary khác. Không có API recovery công khai; công cụ SQL recovery yêu cầu operator xác minh bằng chứng và chain riêng.